Built so patients can trust it

Health information is special personal information under POPIA. MediChain is designed so that every access has a reason, is limited to the people treating the patient, and leaves a record the patient can read.

Who can open a record

Route	How it works
The patient's own grant	A clinician requests access; the patient approves it for a set period (at most 30 days) and can withdraw it at any time.
A care relationship	An appointment, consultation or referral gives the treating clinician access for a limited window.
Emergency (break-glass)	Needs an active work context, an approved device and a reason; the server issues a time-limited grant. The patient sees the access in their history.
Everyone else	Refused. Holding a clinical role is not enough on its own. Administrators manage accounts and devices, not clinical records.

Patients see and decide

- **Access history:** every chart opening and emergency read, with who, when and the stated reason.
- **Consent with a legal basis:** consent is recorded as given or refused, never assumed; withdrawal is kept as a record, not deleted.
- **Notifications reach only the right people:** a patient's reminders go to that patient; clinical alerts go to the patient and the clinicians treating them; administrators receive security alerts only.

How data is protected

Control	Implementation
Passwords	Never sent when signing in: the browser sends a one-way proof (PBKDF2 then HKDF), stored as Argon2id. New passwords must be 15 or more characters and are checked against known-breach lists without sending the password.
Accounts	Authenticator-app (TOTP) step-up for privileged actions; lockout after repeated failures; sessions revocable.
Encryption	HTTPS with security headers and a strict content security policy; encrypted documents (ChaCha20-Poly1305); encrypted disks and backups.
Audit	Access-log and audit rows are batched into Merkle trees, hash-chained, signed (Ed25519) and exported to write-once (Object Lock) storage, so a past record of access cannot be quietly rewritten.
Emergency QR	Carries a server-signed proof, so a typed patient number cannot open emergency access.
Operations	Hosted in South Africa (AWS Cape Town); nightly backups with an automatic restore test; alerts on errors and failed sign-ins.

Honest status: real patient data is gated

MediChain holds fictional data only. Before real patients, seven release gates must close. The engineering gates are in progress; three are legal and organisational:

- a registered Information Officer for the operating company;
- POPIA prior-authorisation and cross-border processing assessments;
- sign-off by a South African health and privacy lawyer.

> Irreversible deletion of clinical records is deliberately not built: records are retired, not destroyed, until retention rules are approved.